CTF参加記録と学習の進め方

参加結果

現地開催のCTFに参加し、200名中99位となりました。
数値列の変換、ファイル解析、ネットワーク解析、Web通信などの課題に取り組みました。

このノートの公開範囲

一般的な技術と調査手順を、学習記録として整理しています。大会の問題文・画像・配布データ、具体的な解答やFlag、問題固有の入力値・接続先は収録していません。例は自作の練習用です
。

調査の基本手順

1. 入力が文字列・画像・通信ログなどのどれかを判定する。
2. 形式や構造から仮説を立てる。
3. 小さな変換や確認を試し、結果を比較する。
4. 元データを残し、手順・結果・未解決点を記録する。

学び

ツールの出力だけで判断せず、データの構造を理解することが重要でした。調査結果と推測を区別し、仮説を検証する進め方を学びました。ここでの記載は全問題の正解を示すものではありません
。

大会ルールの確認状況

大会名・規約URLが未提示のため、公開ルールは未確認です。具体的な解答を除いても公開可否は確定しません。公開前に同梱の確認事項を用い、公式案内の条件を確認してください。

文字列・文字コードの調査

エンコードと暗号の区別

エンコードは表現形式の変換です。暗号化は通常、鍵などの条件を使って内容を保護します。読めない文字列でも、まずは形式の変換を疑い、直ちに暗号と断定しないことを学びました。

16進数・10進数の練習例

自作の例として、同じ文字列「Hello」を異なる数値表現から戻します。入力値と文字コードを対応付けて確認します。

```
printf '%s' '48 65 6c 6c 6f' | xxd -r -p
python3 -c "print(''.join(map(chr,[72,101,108,108,111])))"
```

Base64・モールス信号

Base64は文字の種類や長さから候補を考え、変換結果で判断します。見た目だけでは確定できません。モールス信号は国際・和文などの規格を区別し、対応しない符号を無理に解釈しないようにします。

```
printf '%s' 'SGVsbG8=' | base64 -d
```

文字化け

元のバイト列と、読み込みに使った文字コードを分けて考えます。UTF-8・Shift_JIS・CP932などの取り違えを検討します。未知の文字化けを一つの変換で必ず復元できるわけではありません。

```
iconv -f CP932 -t UTF-8 sample.txt > converted.txt
```

上の例は、元ファイルがCP932と分かっている場合の変換です。置換文字などで情報が失われていると、元データが必要になります。

ファイル・ネットワークの調査

ファイルの初動調査

拡張子だけで判断せず、実データの形式、先頭バイト、可読文字列を確認します。次の例は手元の練習用ファイルを対象とします。

```
file sample.bin
xxd -l 64 sample.bin
strings -a sample.bin | head -n 30
```

PNGの構造

PNGではシグネチャやIHDR・IDAT・IENDなどのチャンクを確認します。表示できることと、内部構造が妥当であることは別に調べます。末尾の追加データだけで不正と断定せず、構造と用途を確認します。

```
pngcheck -v sample.png
```

PCAPと転送データ

通信のプロトコルを特定し、必要なストリームを追います。メール本文や添付、転送ファイルを調べる際は、再構成とデコードを区別します。可読文字列の抽出だけでは、分割されたデータを復元できません。

```
tshark -r sample.pcap -q -z io,phs
tshark -r sample.pcap -Y 'http || smtp || ftp'
```

WiresharkのFollow TCP Streamや、対応プロトコルのExport Objectsを使い、復元したデータの形式を再確認します。TLSなどの暗号化通信は、そのままでは本文を読めません。

Wi-Fi通信

802.11の管理フレームとデータフレームを区別します。暗号化方式や必要な鍵情報などを確認し、取得した通信だけで内容を読めるとは限らないことを学びました。

Web通信・調査記録・公開確認

HTTPで確認する情報

メソッド、ステータス、レスポンスヘッダ、リダイレクト先を確認します。ログインでは、Cookieによる状態管理やCSRFトークンの役割を理解することが重要です。実際の認証値は学習記録に掲載しません。

```
curl -i http://localhost:8000/
```

これは自分で起動したローカルの練習サーバーを対象とする例です。通信の検証は、自分の環境や許可された競技対象で行います。

学習に使ったツール

file：データ形式の推定。
xxd・strings：バイト列と可読文字列の確認。
grep：文字列の検索。
tshark・Wireshark：通信の分類と調査。
curl：HTTPリクエストとレスポンスの確認。

変換候補の確認

DenCodeは、文字列の変換候補を調べる際に利用しました。結果は元データの形式と照合します。外部ツールに入力するのは、自作の例など公開できるデータに限ります。
利用先：https://dencode.com/ja/

次の学習と公開前の確認

今後は、調査ログに仮説・実行手順・結果・未解決点を残し、再現可能な形で整理します。
公開前には大会公式の案内で、公開可否・解禁日・公開範囲を確認します。このノートではルール確認を完了していません。詳細はPUBLICATION_CHECKLIST.mdに記載しています。